

Seguridad y privacidad en línea

Conceptos básicos

Curso: Informática básica modulo 03

Rev.: 02-2026 / V.0.01

Este documento ha sido redactado, maquetado e indexado por Santiago García Santiago
Técnico en Microsistemas y Redes.

Distribuido al amparo de la licencia Creative Commons.

Última revisión: 06-02-26 [06-02-26]



Índices

[01- Principios de las comunicaciones seguras](#)

[02- Identificación de amenazas y riesgos en la red](#)

[03- Protección de privacidad en internet](#)

[04- Contraseñas seguras, primera barrera de seguridad en la red](#)

[05- Conexiones inalámbricas seguras](#)

[06- Configuraciones básicas del router o puerta de enlace](#)

[07- Protección de privacidad en dispositivos móviles](#)

[08- Protección de datos, los derechos que tiene el usuario](#)

01- Principios de las comunicaciones seguras**[Modulo 01]**

Estos puntos son los pilares fundamentales que rigen nuestro sistema de comunicaciones, a la hora de diseñar nuevos modelos siempre se recurre a ellos como principios inalienables.

Confidencialidad

Garantiza el secreto de todas las comunicaciones que podamos establecer en cualquier dispositivo electrónico. Únicamente el emisor y receptor del mensaje han de poder acceder a él.

¿Qué implica de cara a las ISP?

La obligatoriedad de uso de sistemas de cifrado seguros (auditados y vigilados por organismos especializados) el no emplear estos métodos, implicaría la revocación de las licencias de ejercicio.

Integridad

Garantiza la “integridad” del mensaje, elemento multimedia, paquete o aplicación que descargamos de la red.

¿Qué implica de cara al usuario?

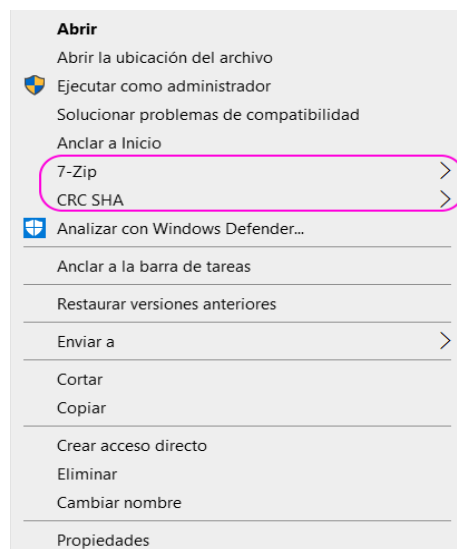
Garantizar la integridad de un sujeto digital, implica la seguridad de que ese elemento que estamos descargando, no ha sido manipulado por un cibercriminal.

¿Qué herramienta nos permite verificar la integridad?

Existen múltiples herramientas online, en ellas podremos calcular el HASH (o identificador único de archivo) del elemento que estemos descargando, el proceso es sencillo:

HASH (del la pagina de descarga) = **HASH** (de nuestro paquete)

En Microsoft Windows, el método más sencillo y concurrido es hacer uso del visor de HASH integrado en la herramienta de compresión 7z.



01- Principios de las comunicaciones seguras

(Continuación)

Autenticidad

Este principio garantiza la autoría del mensaje, mediante la implantación de una serie de protocolos que actúan “firmando” los paquetes que generamos. Con ello podemos rastrear el origen de las comunicaciones garantizando la legitimidad y que esta es “cierta, genuina y verdadera”.

Disponibilidad

Esto garantiza el poder acceder a la información en caso de un accidente o “interrupción” de las comunicaciones y al mismo tiempo que la información pueda estar disponible en cualquier momento para las personas autorizadas.

¿Cómo aplican este principio las ISP?

Manteniendo una copia del perfil de navegación del usuario durante un periodo de tiempo concorde a la legislación del país donde operan. Esta huella digital está cifrada (ilegible para el ISP) y doblemente anonimizada.

¿Los gestores de descarga / streaming también conservan datos?

Sí; aunque en este caso al igual que con la huella de navegación, también están cifrados, pero sometidos a los requisitos de seguridad del país en el que operan.

Como proteger con software:

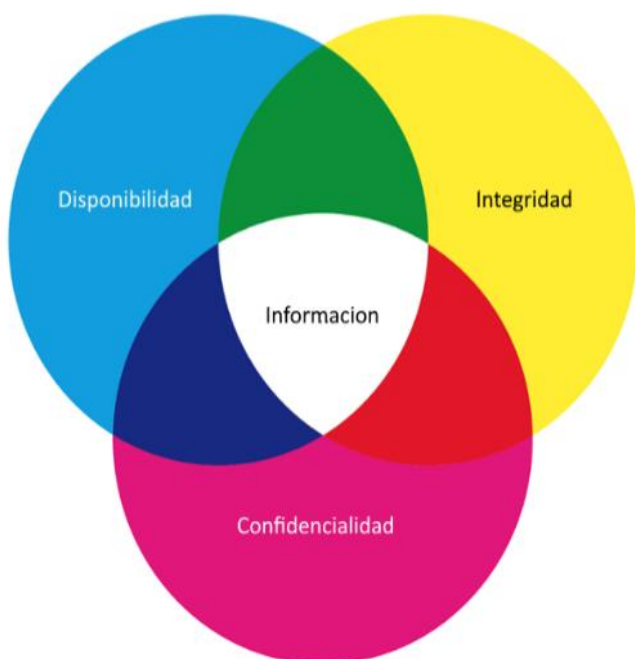
- Barreras antivirus (Defender)
- Descargar de fuentes o repositorios fiables, o páginas oficiales.
- Actualizar las aplicaciones.
- Control de actualizaciones

Como proteger las comunicaciones:

- Canales de comunicación cifrados.
- Control de las conexiones en la red.
- Evitar spam y publicidad.
- Protocolos / aplicaciones seguras: SSH, VPN, TLS /SSL

Como proteger los datos:

- Copias de seguridad.
- Almacenamiento cifrado.



02- Identificación de amenazas y riesgos en la red

Tipos de ataques o amenazas informáticas:



Tipos de protecciones o contra medidas informáticas:



Perfiles de Cibercriminales / Súper usuarios en la red:

Usuario

Persona que maneja cualquier dispositivo IT, sin necesariamente conocimientos avanzados de redes o sistemas.

Hacker

Individuo con altos conocimientos en administración de sistemas y programación de scripts. Pueden ser auto-didactas o estudiantes / graduados de ingenierías informáticas.

Hacker:

- Respeta la ley
- Respeta la privacidad
- No altera códigos
- Solo busca fallos de seguridad
- Repara, restaura y protege

¿Qué no es un hacker?

Un criminal. La palabra Hacker, procede del argot informático norteamericano y hace referencia a "curioso". Originariamente los Hacker, simplemente curioseaban los sistemas "colándose" en ellos e informando a los propietarios de los mismos de sus fallos de seguridad.

Actualmente, no todos los ingenieros informáticos ni gestores de seguridad aceptan que se les tilde de "hackers". Es un término que solo resulta atractivo para la gente muy joven (por el ansia de pertenecer a un "grupo" exclusivo) y showmans. Televisivamente es un término que vende (aparte de tener toda una estética y gestualidad ya definida). [●][●][●]

Cracker

Cracker:

- Carece de ética o moral
- Roba y extorsiona
- Crea todo tipo de virus y malware
- Oculta puertas traseras y crea fallos
- Manipula, daña, secuestra y destruye

Es el cibercriminal por excelencia. Suelen ser individuos de muy altas aptitudes técnicas, en algunos casos excepcionales. Muchos de ellos proceden del campo académico, y tras alcanzar las cotas más altas de conocimiento son tentados por organizaciones criminales que les ofrecen un alto nivel de vida.

Otros simplemente son autodidactas, con capacidades de análisis e ingeniería inversa superiores a la media, habilidades que les permiten entrar prácticamente en cualquier sistema (por muy altos que sean sus perfiles de seguridad) y hacer lo que se les antoje. [•]

-Perfiles Cracker existentes-

-Criminal-

Pertenecen a organizaciones criminales, crean su malware con objetivos de difusión muy definidos (instituciones públicas, empresas de alto valor, infraestructuras)

-Militar-

Son “reclutados” por servicios de inteligencia o formados por unidades militares de guerra cibernética. Se especializan en malware de inutilización de infraestructuras públicas y telecomunicaciones.

-Solitario-

Individuos autodidactas que ofertan sus servicios para realizar todo tipo de ataques, robos de datos o “destrucción” de empresas u organizaciones mediante ransomware hecho a medida.

Lamer

Lamer:

- Carece de conocimientos técnicos
- Emplea herramientas de Crackers y Hackers
- Siempre provoca desastres informáticos.

Usuario que carece de formación técnica, pero irresponsablemente asume riesgos suicidas al navegar y profundizar en áreas de internet propias de los Crackers, con el fin de hacerse con “herramientas” de malware para aparentar ser “Hacker” o “Cracker” de cara a la opinión pública.

Suelen provocar daños irreparables en los sistemas informáticos de las empresas o instituciones donde trabajan o estudian.

Identificación de amenazas y riesgos en la red

[Continuación]

Catalogo de amenazas:

Qué es el malware

(Categoría general: software malicioso)

Es el término genérico para referirnos a todo el software malicioso que se instala en nuestro sistema sin nuestra autorización ni conocimiento. En etapas anteriores de la informática, este tipo de software se denominaba “virus” y era de carácter exclusivamente destructivo. Actualmente el malware busca recopilar información sensible del usuario, para posteriormente o bien venderla a terceros (en la deep web) o extorsionar al usuario / empresa.

<https://www.youtube.com/watch?v=11Ww1WF0-0s>

¿Qué es el secuestro del sistema en un malware?

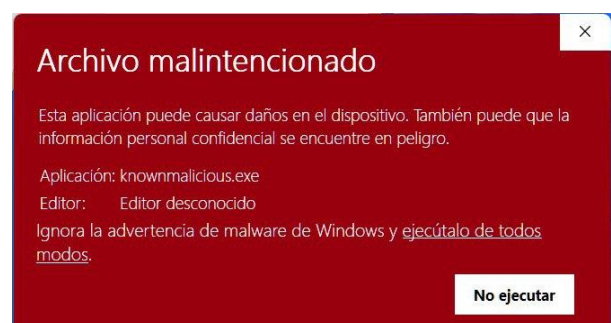
El concepto de “secuestro del sistema” hace referencia al empleo de un “rootkit” que no es más que un software de administración remota, que permite al atacante hacerse con el control “total” del sistema del usuario, sin que este lo perciba.

¿Cómo consigue le atacante acceso total a nuestro sistema?

Engañando al usuario para que ejecute/instale un software manipulado con un malware en su interior. El 99% de los “rootkits” requieren del usuario para poder instalarse e iniciarse en un sistema.

¿Podemos identificar las aplicaciones infectadas con rootkits?

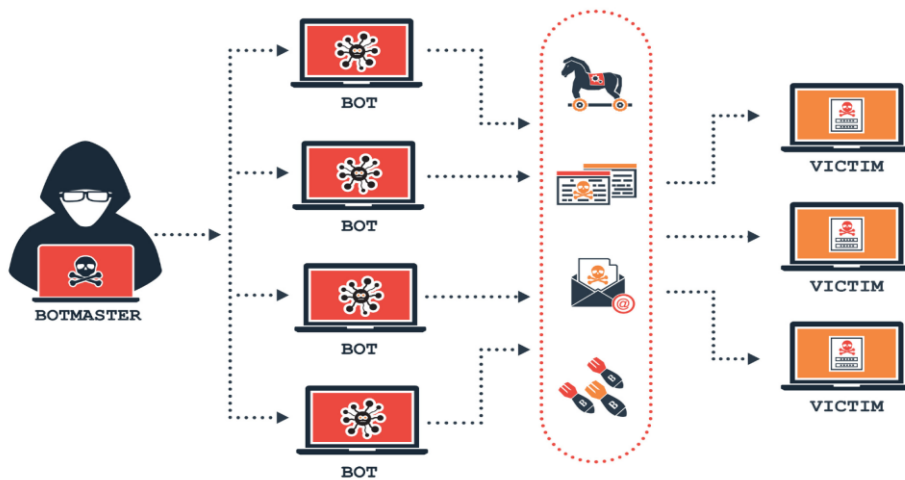
Sí; todos los antivirus del mercado (incl. Windows defender) disponen de bases de datos compuestas por cientos de miles de HASH de “rootkits” y malware. Aparte de poseer sistemas de detección por análisis heurístico.



¿Qué es el botnet en un malware?

Una “botnet” o “red zombi” es el producto de cientos o miles de sistemas infectados por un malware “rootkit”. El cracker se hace dueño de todos los sistemas infectados, empleándolos al unisonó para efectuar ataques de gran envergadura a otros objetivos. Ataques DDoS (Denegación de Servicio Distribuido), envió masivo de spam o enlaces de Phishing, hospedamiento de webs maliciosas...

Ejemplo de arquitectura y uso de un botnet:



¿Qué es el adware en un malware?

Un “adware” es un paquete de software malicioso que se hace pasar por software legal. Por lo general imita tanto en apariencia física como en funcionamiento al software que trata de hacernos creer que es. En la mayoría de las ocasiones se llega a él, tras un “popup” o ventana emergente de publicidad invasiva.

Señales de infección:

Anuncios que aparecen incluso sin estar conectados a internet, barras de herramientas “nuevas” en el escritorio, página de inicio del navegador cambiada (y no se puede modificar).

Adware publicitario:

Es un software malicioso que se muestra como publicidad, su fin es recopilar todo tipo de información del usuario para posteriormente mostrarle publicidad de modo abusivo. Los datos que recopila son de todo tipo, sin censura ni respeto por la privacidad.

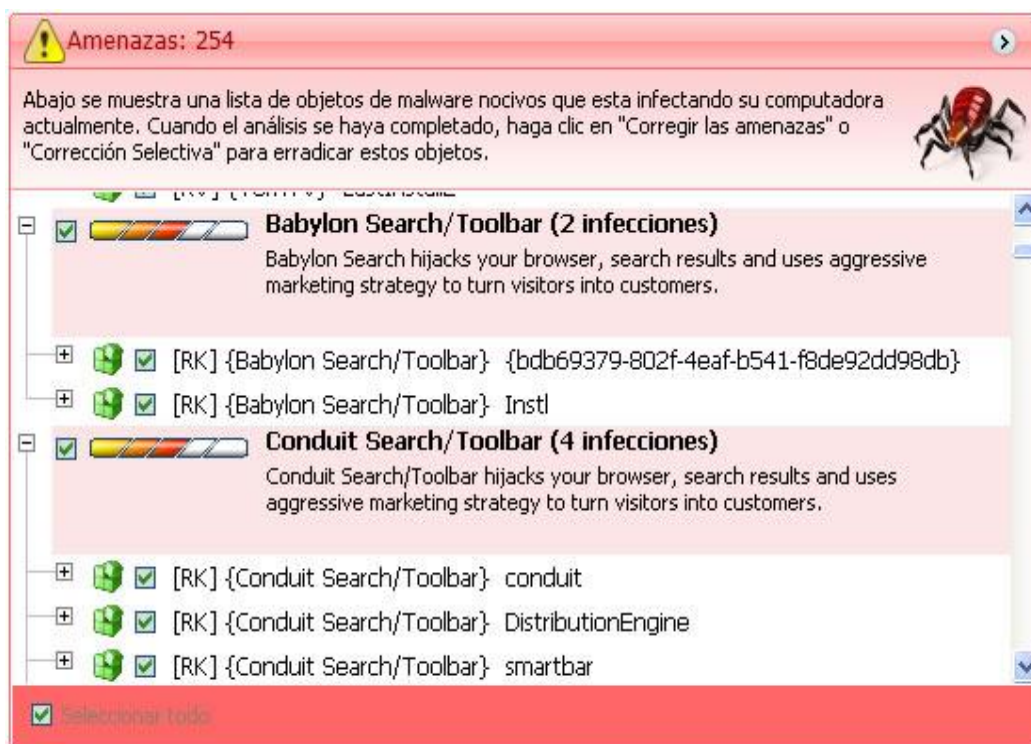
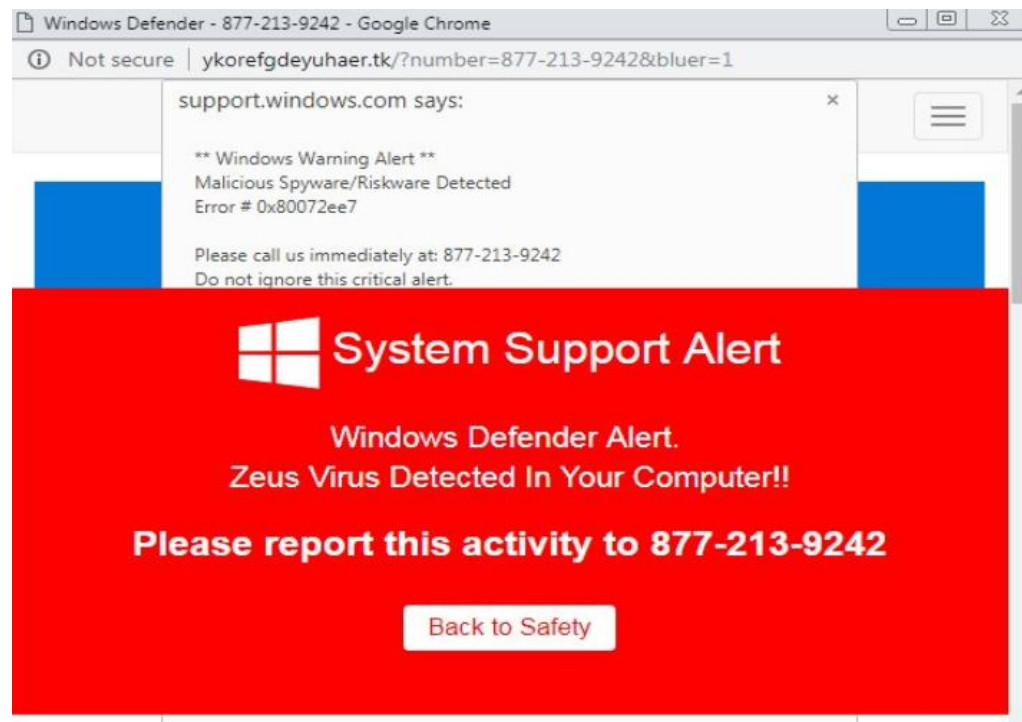
Adware Rogueware:

O “falso antivirus” Un Rogueware (término surgido de la unión de las palabras inglesas Rogue y malware) es una forma de software malicioso que engaña a los usuarios haciéndoles creer que hay un virus en el ordenador, cuando en realidad él es el software malicioso.

Atención

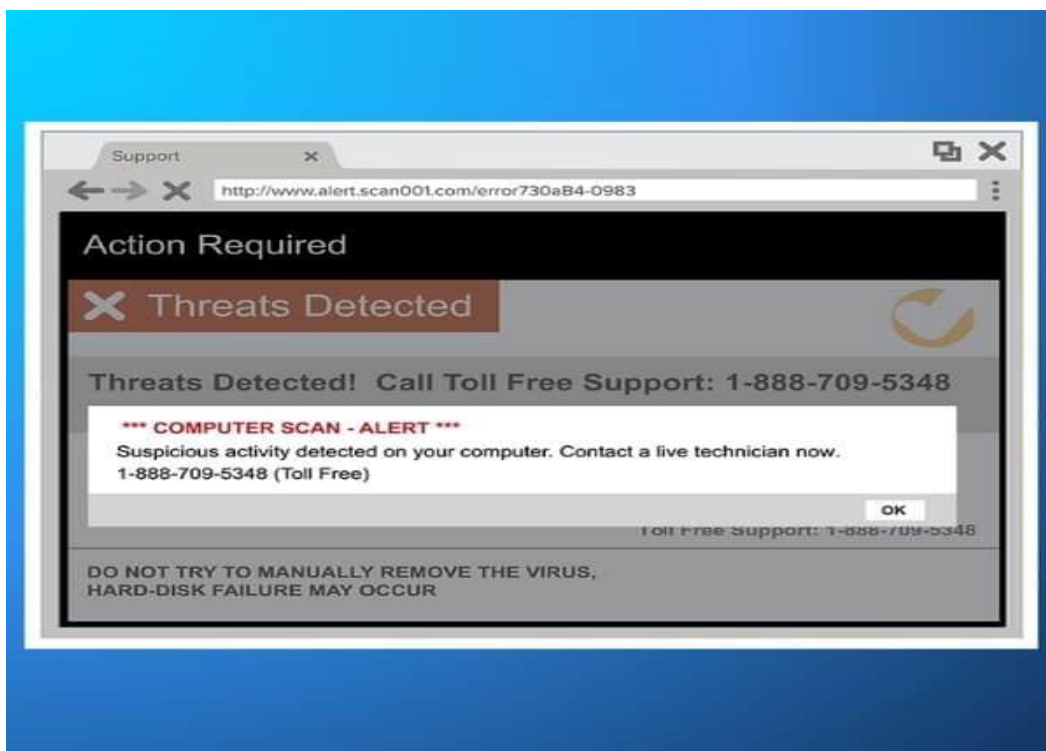
El sistema del usuario no puede ser “analizado” remotamente sin que el propio usuario haya gestionado el antivirus online. Ninguna empresa analiza los datos del usuario sin autorización ni solicitud previa por parte de este. **NUNCA**

Ejemplos de adware Rogueware:



Ejemplos de adware Rogueware:

[Continuación]



Ejemplos de adware Rogueware:

[Continuación]



¿Qué es el spyware en un malware?

Es un software malicioso que infecta un sistema para después monitorizarlo, robando información de modo silencioso, transmitiendo está a terceros sin el conocimiento del propietario del equipo. [•]

La variante más peligrosa del spyware:

Keylogger; es un spyware que captura todas las pulsaciones que realiza el usuario en su teclado, remitiendo esta información al atacante. Al igual que el spyware requiere del engaño del usuario para que sea el mismo quien lo instale en su sistema.

Usos reales de Keyloggers

Casos de uso malicioso	Casos de uso legítimos
• Robo de identidad • Vigilancia • Espionaje corporativo	• Controles parentales • Supervisión del lugar de trabajo

¿Qué es un troyano en un malware?

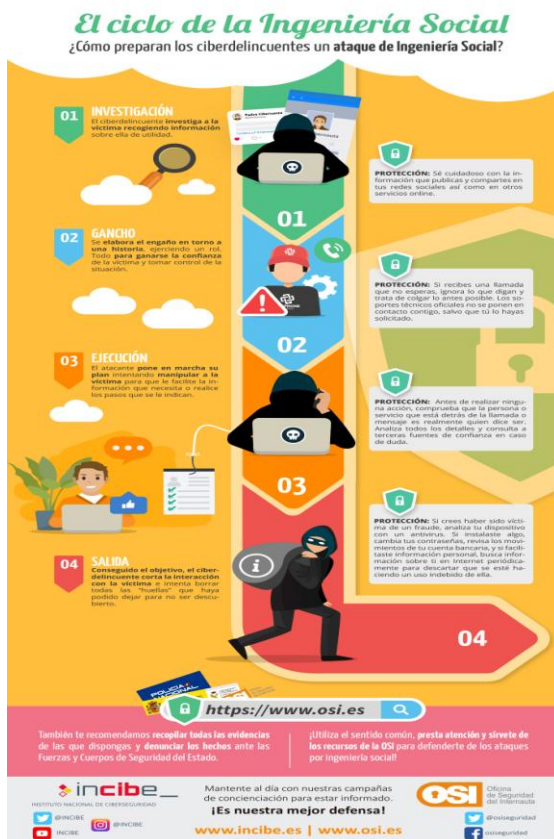
Es un tipo de malware que se oculta en el interior de ejecutables de aplicaciones aparentemente inofensivas. Al instalarse puede provocar todo tipo de daños; desde el secuestro del sistema, creación de backdoors, instalación de Rootkits o incluso spywares.



©2025 Trend Micro

¿Qué es el ataque por ingeniería social?

Un ataque por ingeniería social, está basado en la explotación de vulnerabilidades psicológicas en lugar de técnicas. Son tácticas diseñadas para engañar al usuario y que este facilite datos sensibles sin ser consciente de ello. [•][•][•]



¿Cómo funcionan los ataques por ingeniería social?

Son muy sofisticados, se suelen hacer “a medida” de la víctima, para ello el cracker investiga las redes sociales del usuario, adquiriendo de este modo todo tipo de datos privados que el propio usuario muestra en público sin ser consciente del peligro. Tras esto, analizando estos datos, el cibercriminal diseña un ataque destinado a obtener datos que le permitan hacerse con cuentas bancarias, correos electrónicos o incluso las propias redes sociales del usuario víctima. Estos ataques son devastadores, puesto que no solo pueden centrarse en robos, también en provocar que el usuario instale software malicioso en organizaciones (sin ser consciente de ello).

Qué es el ransomware

Un ransomware o 'secuestro de datos' en español, es un tipo de programa dañino que restringe el acceso a determinadas partes o archivos del sistema operativo infectado y pide un rescate a cambio de quitar esta restricción. Es el malware más extendido en estos comienzos del siglo XXI. [1][2][3]



¿Pagar el rescate garantiza la recuperación de dato?

No; solo temporal o momentáneamente. Este tipo de malware es PERSISTENTE los más sofisticados se introducen tanto en los discos de almacenamiento como en la propia BIOS.

¿Es fácil que nos infectemos de ransomware?

No; son aplicaciones maliciosas desarrolladas para atacar a organismos públicos, grandes cadenas comerciales y empresarios / personalidades de alta posición social. En raras ocasiones los usuarios “domésticos” llegan a sufrir este tipo de ataques.

¿Cómo se puede infectar un usuario común con un ransomware?

Por tres vías:

- Descarga de supuestas aplicaciones o herramientas hacker o cracker, en webs o foros de dudosa procedencia.
- Descarga y ejecución de aplicaciones piratas, supuestamente “adaptadas” “recortadas” u “optimizadas” (como los sistemas operativos más “ligeros”).
- Descarga y ejecución de supuestos “juegos” o “películas” que ni siquiera han salido a la venta (¿?)

Qué es el malvertising

Son banners publicitarios que animan al usuario a instalarse una extensión del navegador, o una aplicación bajo el pretexto de poder acceder a una oferta o servicio increíblemente atractivo. [•]

¿Has sido víctima de *malvertising*?

Puede que alguna vez te haya saltado un *banner* con información que a simple vista parece poco fiable.

La publicidad engañosa o *malvertising* es una técnica mediante la cual los ciberdelincuentes inyectan *malware* en anuncios publicitarios de la Red.



¿Cómo puedo identificarlo?

- ◇ Determina la fuente de los anuncios, si no puede tratarse de publicidad maliciosa.
- ◇ Analiza el lenguaje y la forma del anuncio, ya que en el *malvertising* se suelen utilizar mensajes llamativos.
- ◇ Reconoce los *pop-ups*, la publicidad maliciosa recurre al uso de los mismos.
- ◇ Comprueba que la URL de la página web de destino sea sencilla. Si te resulta sospechosa, no se corresponde con el sitio web.

Qué es el typosquatting

Cualquier usuario puede registrar un dominio, aprovechando este detalle, los ciberdelincuentes registran en masa, cientos, miles de variaciones de dominio de aspecto similar a paginas oficiales. De este modo al introducir erróneamente la url de una página, el usuario es redirigido a una “replica” de la misma, pero infectada de software malicioso. [•]

✗
g00gle.com
i

✗
guogle.com
i

✓
google.com

✗
gogle.com
i

✗
goog1e.com
i

Live Law.

www.app1.com

www.facembook.com

www.google1.com

www.micros0ft.com

www.twitter.com

¿Cómo podemos evitar este ataque?

Asegurándonos de estar empleando la url correcta. Siempre hay que mirar la barra de direcciones, y sospechar ante la aparición de “banners” que no habíamos visto antes, colores extraños, o solicitudes de “instalación de complementos” que aparecen insistentemente cuando nunca antes lo habían hecho.

Qué es el Phishing

Es cuando recibimos un correo electrónico no solicitado en nombre de una entidad con la que en circunstancias cotidianas, pudiéramos tener algún tipo de relación o trato.

Este mensaje suele ser FALSO, es una manipulación criminal para que facilitemos datos que les permitan acceder a nuestros servicios (cuentas bancarias, correos, cuentas de servicios stream) [•][•]

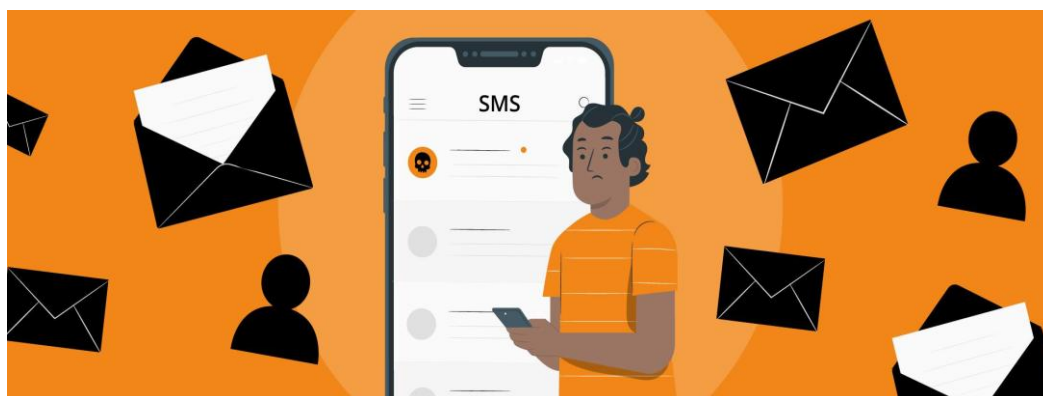
Phishing

Siempre solicitan datos que las propias fuentes que dicen ser jamás nos pedirían.

- Perfiles de usuarios [identificador de usuario - contraseñas]
- Nos piden “clicar” en un enlace dentro del cuerpo del mensaje, para realizar la entrada a nuestra cuenta o servicio.

Qué es el Smishing

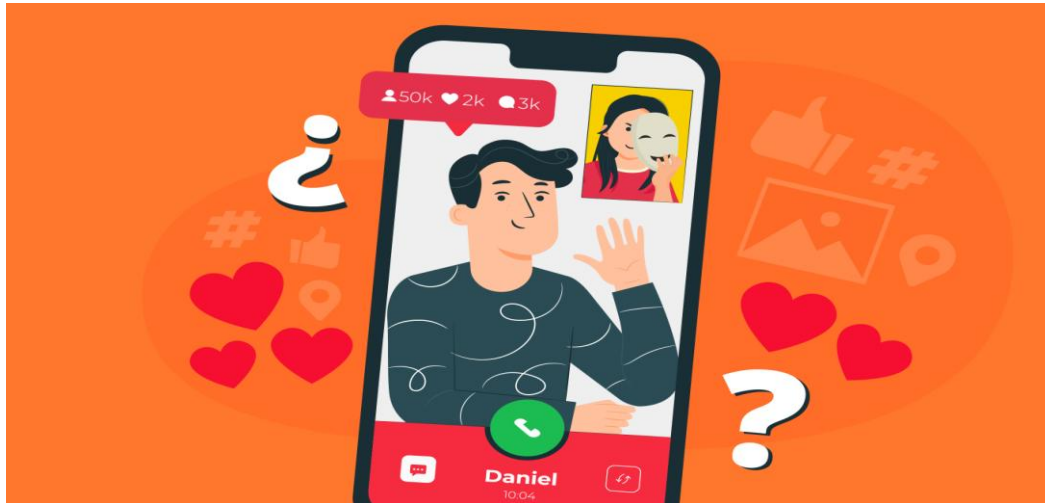
Es cuando el cibercriminal manda masivamente mensajes de texto “informando” al usuario de la recepción de un pedido, o una carta de organismo oficial (multa, comunicado de hacienda, Endesa...) que requiere de que el usuario entre en una dirección de correo específica. [•]



- Si recibe un mensaje de texto de una fuente desconocida, no responda ni haga clic en ningún enlace que pueda incluir. Si tiene duda, comuníquese directamente con la empresa o la organización que supuestamente envió el mensaje a través de su sitio web oficial o número de teléfono, nunca respondiendo directamente al SMS.
- Si recibe un mensaje de texto de una empresa u organización conocida, verifique la autenticidad del mensaje antes de hacer clic en cualquier enlace o proporcionar ningún tipo de información. Contacte directamente con la empresa o averigüe si a través de su web puede confirmar si el mensaje es legítimo o no.

Qué es el Catfishing

Es una de las más perversas técnicas de extorsión que emplean los cibercriminales. El cibercriminal crea un perfil falso en una red social, este perfil suele ser muy atractivo visualmente y esta creado para transmitir riqueza, alto nivel de vida, exclusividad e incluso una estética única, propia de modelos o personas muy agraciadas. [1]



Este tipo de ataque solo busca “enamorar” al usuario, y tras ganarse su confianza empezar a extorsionarle “cariñosamente” con peticiones económicas interminables. Este tipo de estafa cuenta con la variante “del famoso”. [2][3][4]

Aparte del daño psicológico y económico que puede sufrir el usuario victimizado, otro gran peligro de este ataque es el que se transforme en Sextorsión.

03- Protección de privacidad en internet

Concepto de identidad digital

Todos los usuarios de sistemas digitales, aceptan (aunque sea de modo inconsciente) que la imagen que transmiten en la red, no siempre es la misma que les representa en el mundo real.

¿Qué define una identidad digital?

Lo que define una identidad digital son dos principios, la imagen que transmite “conscientemente” el usuario, y el reflejo, que no es más que el producto de la interacción que provoca el usuario con el resto de habitantes de la red.

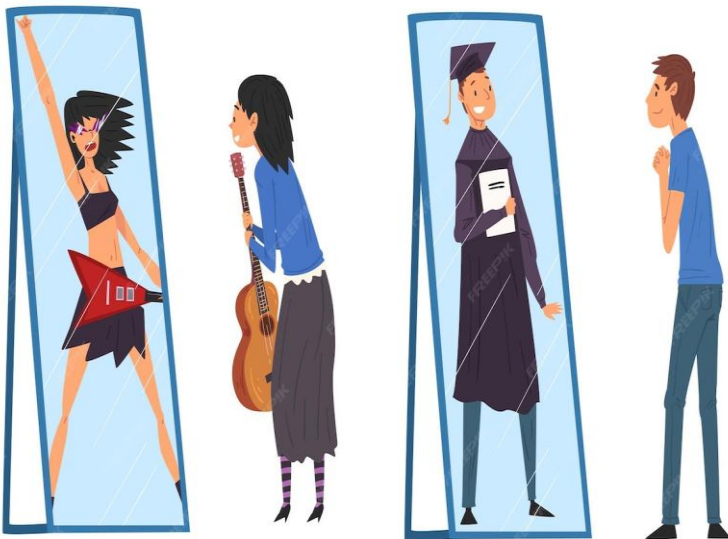


Imagen que transmitimos:

- Imágenes posadas
- Ostentación de riqueza
- Mejores habilidades
- Comentarios sinceros...

Imagen reflejada (interacción)

- Seguidores
- Admiradores
- Iguales, o “Haters”.

¿Nuestra interacción en la red es anónima o privada?

No. La red está regida por el mismo principio de Isaac Newton “a toda acción corresponde una reacción de la misma magnitud o intensidad” Esto quiere decir que todo lo que volquemos en la red, puede volver a nosotros de un modo u otro.

Peligros de una sobreexposición en la red

Si nos adentramos en el entorno digital, sin tomar unas medidas mínimas de seguridad para preservar nuestra intimidad y/o privacidad, podemos ser víctimas de “Haters” y hostigadores profesionales de todo tipo.

Compendio de buenas prácticas en entornos sociales en la red:

[01] Emplear avatares (no una fotografía que nos identifique)

Al emplear un avatar, dificultamos que los cibercriminales puedan recurrir a herramientas de reconocimiento visual, que les facilite recopilar datos privados nuestros con los que poder orquestar un ataque por ingeniería social.

Otra práctica muy recomendada es emplear “diferentes avatares” en base a la red social en la que estemos interactuando.

Compendio de buenas prácticas en entornos sociales de la red:**[Continuación]****[02]** Utilizar “*nickname*”, apodos o solo parte de nuestro nombre.

Nuevamente no tenemos que sobre exponer nuestra identidad para poder hacer uso de las redes sociales. No es recomendable (y es peligroso) introducir todo nuestro nombre completo (nombre y apellidos) como identificador de usuario.

¿Podemos repetir apodos?

Sí y no. Si nuestra actividad en la red es polémica o provoca ataques (gracias al ambiente beligerante y extremista de este comienzo de siglo XXI) no, si nuestro feedback es positivo, sí.

[03] No utilizar correos importantes o de trabajo como “log” de red social.

Una práctica común en todas las empresas de **RRHH** es la de emplear herramientas de rastreo, para buscar todos los lugares en los que el “candidato” está presente en la red.

Otro inconveniente de emplear un correo de trabajo o de contacto como log de una red social, es la posibilidad de que el usuario sea atacado por un hater o un cibercriminal que decida secuestrarle o robarle, la cuenta de correo.

[04] Jamás definir como “publica” la información de contacto o dirección física del usuario.

En este caso creo que son obvias las consecuencias de cometer esta temeridad. Sobran comentarios. (...)

[05] Jamás subir a la red, ningún contenido que no mostraríamos en público o a personas desconocidas.

Una vez el usuario “sube” cualquier material a la red, este es irrecuperable, aunque configuremos su distribución como “privada” esto no quita que algún conocido o cibercriminal pueda hacer una copia de ese contenido para posteriormente, volver a distribuirlo.

El usuario siempre pierde el control del material que sube a la red

¿Si seguimos estas recomendaciones seremos usuarios anónimos?

No, NO EXISTE EL ANONIMATO EN LA RED CONVENCIONAL, todos los usuarios estamos identificados tanto por nuestra ISP como por la propia red social en la que estemos actuando. Si seguimos estas pautas solo conseguiremos anonimizar nuestra identidad lo suficiente, como para no ser víctimas de Haters u hostigadores, así como para tener una base de protección contra ataques de ingeniería social.

Recuerde

Nuestra identidad en la red está definida por nuestras acciones e interacciones. No existe la anonimidad en nuestras acciones, aunque creamos estar seguros por no mostrar nuestra imagen y nombre real.

Las fuerzas de seguridad del estado pueden identificar toda nuestra actividad e incluso rastrear nuestra ubicación a tiempo real, si así lo determina un juez.

Conceptos de seguridad en redes sociales

¿Qué son las redes sociales?

Las redes sociales nacieron como una ágora o entorno publico en el que los usuarios pudieran encontrar a sus conocidos, amigos e incluso contactos con personas de características afines.

¿Qué son a día de hoy las redes sociales?

Las redes sociales han evolucionado hasta convertirse una suerte de escaparate social/político ultra-influenciado por los intereses económicos y políticos de los multimillonarios que las gestionan.

Principales redes sociales:



Facebook

SEO fundador: Mark Zuckerberg

Creación: 02-02- 2004



Instagram

SEO fundador: Kevin Systrom y Mike Krieger

Creación: 01-10- 2010



LinkedIn

SEO fundador: Reid Hoffman

Creación: 01-05- 2003



TikTok

SEO fundador: Zhang Yiming

Creación: ¿?-¿?- 2012



X (Twitter)

SEO fundador: Jack Dorsey

SEO actual: Elon Musk

Creación: 21-03- 2006



04- Contraseñas seguras, primera barrera de seguridad en la red**[Modulo 03]**

La contraseña es la primera opción de seguridad de cualquier aplicación social en la red, junto al correo electrónico o Log.

“El mejor método para guardar un secreto, es gritarlo a voces”

Oscar Wilde [1854- 1900]

¿Cómo han de ser las contraseñas?

Las contraseñas siempre han de tener una extensión mínima de 6 caracteres, pudiendo esto aumentar hasta la cantidad que sugiera la propia web o aplicación digital. Aun así siempre hay que tener en cuenta los siguientes puntos.

[01] Una contraseña “segura” ha de ser alfanumérica (contener letras y números) así como mayúsculas y minúsculas.

[02] Una contraseña “segura” jamás es una fecha conmemorativa del usuario o su entorno (año de nacimiento, o año de nacimiento de los hijos, de la celebración de una boda...)

[03] Una contraseña “segura” nunca es el nombre de una “afición” (equipo de fútbol al que se sigue, cantante al que se escucha) o hobby del cual el usuario alguna vez haya hablado en la red.

[04] Una contraseña “segura” nunca es el nombre de una mascota (aunque esta haya fallecido) o familiar.

¿Se puede repetir la contraseña?

No. Las contraseñas siempre han de ser diferentes. Emplear la misma contraseña para todas las aplicaciones / servicios de la red, es exponerse a que si uno de esos servicios es crackeado, el cibercriminal tendrá acceso a todos los demás sin tener ni siquiera que esforzarse.

¿Qué quieren decir cuando avisan que han crackeado una web / empresa?

Cuando vemos un anuncio de “ataque” a una empresa [●][●][●] lo que están trasladando a los usuarios es que si tenían una cuenta con ellos (un usuario, password) esos datos están comprometidos, y un cibercriminal podría emplearlos para entrar en nuestro perfil/servicio.

¿Cómo debemos proceder tras conocer la existencia de un ataque?

Cambiando de inmediato las contraseñas que hayan sido comprometidas. Sin demora. Legalmente las empresas tienen la obligación de informar a los usuarios con un máximo de 24h desde que tienen noticia del ataque, aunque en España las empresas ignoran esta ley, amparándose en “la distribución de la noticia por los sistemas periodísticos”, una vez la noticia se hace pública, la responsabilidad de proteger sus datos, solo es del usuario.

¿Cada cuanto hay que cambiar una contraseña?

Lo ideal sería mensualmente. Lo práctico es cada 6 meses, y lo que suelen hacer los usuarios responsables es una vez al año.

Contraseñas con verificación de dos pasos

La autenticación de dos factores (A2F o doble factor de verificación) consiste en utilizar dos canales diferentes de verificación, siendo uno de ellos desde el que se solicita el acceso al servicio/aplicación y el segundo, un elemento (ya sea de hardware o software) que solo puede tener el usuario legítimo del perfil de log.

¿Es recomendable tener activada la doble verificación?

Sí, dificulta enormemente los ataques por ingeniería social, los ataques o intentos de suplantación de identidad y los posibles secuestros o robos de perfiles.

¿Es infalible la doble verificación?

No. Los cibercriminales cuentan con tres métodos para poder romper este sistema de protección, aunque todos ellos requieren de cierto nivel de conocimientos y capacidad de infraestructura.

Método 01/02 de rotura de doble verificación:

Duplicación de SIM o eSIM

El cibercriminal, obtiene por ingeniería social, el número de teléfono principal del usuario. Empleando toda la información del usuario víctima, se hace pasar por este, y solicita un “duplicado” de teléfono consiguiendo de este modo, interceptar el mensaje de doble confirmación.

¿Es común este ataque?

En España no, pero sí en LATAM y en Europa del este.

*Comentar anécdota.

Método 02/02 de rotura de doble verificación:

Robo de teléfono móvil

El cibercriminal, compra el teléfono “robado” y tras entrar en él y obtener los datos por ingeniería social, trata de entrar en los perfiles bancarios o sociales del usuario víctima.

¿Es común este ataque?

Si, en todo occidente, para robo de datos de empresa. Es uno de los ciberdelitos más comunes.

05- Conexiones inalámbricas seguras

Una de las principales novedades de este siglo XXI fue la irrupción de las comunicaciones inalámbricas de “banda ancha”. Los conocidos como sistemas “Wifi”.

¿Qué es realmente el Wifi?

El Wifi es un sistema de emisión-recepción de señales digitales del mismo modo que en el pasado emitíamos señales de radio o televisión (UHF). La principal diferencia con estas últimas es la frecuencia de emisión y su intensidad. El Wifi como usted ya conocerá tiene un alcance limitado, pero dentro de su rango una alta velocidad.

¿Se puede proteger la información en una señal Wifi?

Si, mediante sistemas de cifrado. Para el ámbito civil existen tres sistemas de cifrado de señales Wifi.

Cifrado

WEP (Wired Equivalent Privacy)



Sistema de cifrado empleado masivamente a finales del pasado siglo XX. Utilizaba un algoritmo de cifrado RC4 con claves estáticas. Actualmente totalmente desfasado e inservible, se rompe con extrema facilidad.

No emplee el cifrado WEP es un sistema obsoleto

Cifrado

WPA



Sistema de cifrado que reemplazo al método WEP, emplea TKIP (Protocolo de integridad de clave temporal) para generar claves dinámicas. Es más robusto que el anterior, pero actualmente se rompe con sencillez. Se considera obsoleto, e inservible.

No emplee el cifrado WAP es un sistema obsoleto

Cifrado

WPA2 / WPA3



Es el sistema de cifrado civil utilizado actualmente. Es el más seguro, únicamente rompible por servicios de inteligencia. Utiliza cifrado AES de 128 bits.

Utilice siempre el sistema de cifrado WPA2 – WPA 3

05- Conexiones inalámbricas seguras

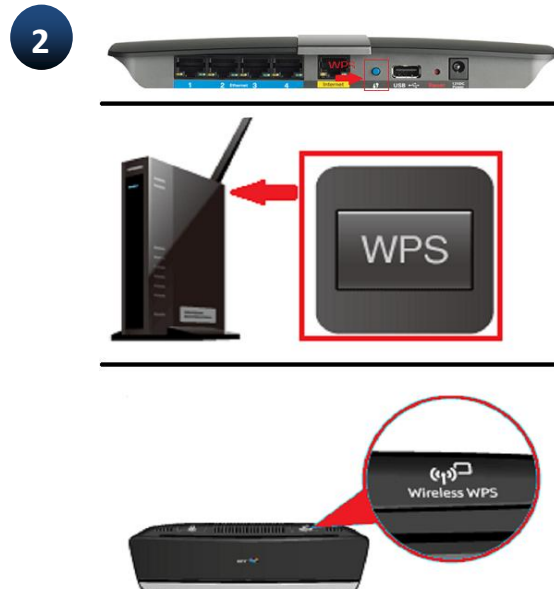
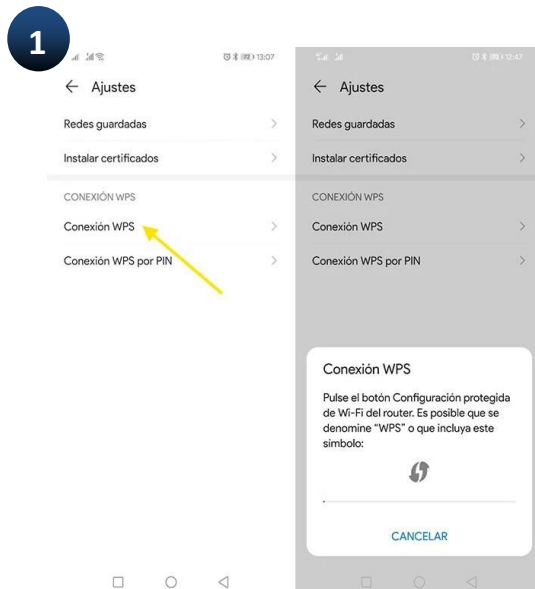
[Continuación]

WPS – Sistema de autoconfiguración Wifi



Uno de los métodos más sencillos de conectar un dispositivo al router o puerta de enlace, es realizando una sincronización o “WPS”. Aunque este método es muy sencillo y útil, no es aconsejable abusar de él. El problema que presenta es que maneja una clave muy reducida (8 dígitos) y un supuesto cibercriminal, tardaría segundos en romperla.

**Utilícelo solo en ambiente
domestico, nunca en empresas o
áreas públicas**



Peligros de una conexión publica

Todos los días al movernos por las ciudades nos vemos en la obligación a conectarnos puntualmente a nodos de acceso públicos. Al hacerlo es conveniente seguir unas pautas mínimas de seguridad.

Recomendaciones de seguridad en redes públicas

[01] Asegurarnos de la entidad/empresa que gestiona el nodo de acceso.

El nodo al que enlacemos nuestro dispositivo iT tiene que habérse nos facilitado por algún empleado o miembro del local o entidad (miembro de la cafetería, banco, aeropuerto)

[02] La contraseña de acceso tiene que coincidir con la que nos han facilitado.

Nunca se conecte a una red que muestra su contraseña en el tag o identificador.

[03] Nunca se conecte a una red que en su tag, anuncie que es “gratuita” “free” o “clientes”

[04] Aun siendo “supuestamente” segura, evite entrar en su perfil de entidad bancaria siempre que le sea posible. En caso de no poder evitar entrar en su entidad bancaria, emplee preferentemente, los datos de su dispositivo no la red pública.

Recomendaciones de seguridad en redes públicas**(Continuación)**

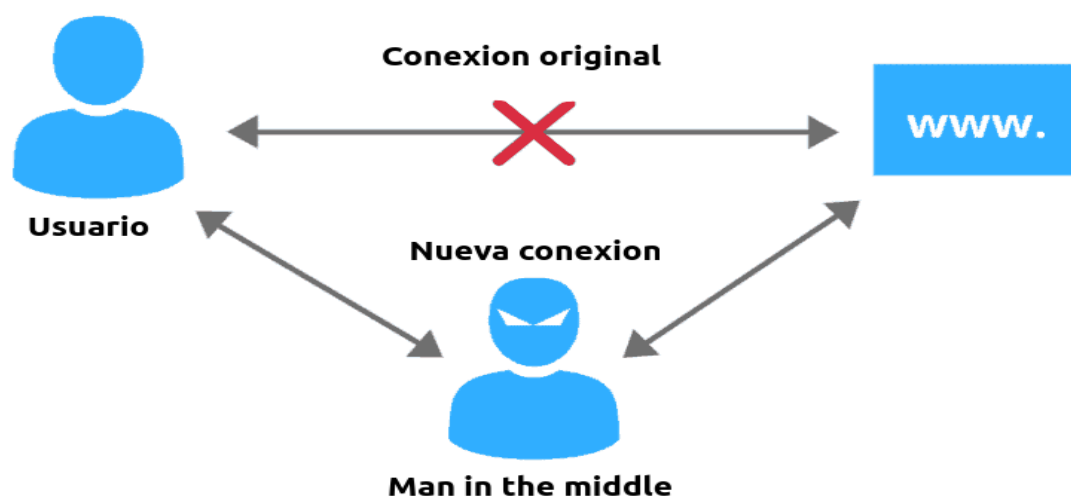
[05] No acepte nunca conectarse mediante un puente de red (compartición de red por parte de un empleado o supuesto personal)

Evite siempre que le sea posible conectar a su entidad bancaria desde una red pública.

Haga caso a sus “corazonadas” si algo se le hace extraño (por mínimo que sea) desconéctese del nodo. Los cibercriminales suelen cometer errores por descuido que no siempre percibimos de modo consciente (una letra en un título mal puesta, un tono de color en un logo que aunque se parece no corresponde con el original, una falta ortográfica que nunca antes había visto...)

Redes públicas ataque [Man in the Middle]

El mayor peligro de las redes públicas es el que un cibercriminal cree un punto de acceso (o nodo) imitando al del propio emplazamiento, para que los usuarios lo empleen creyéndose seguros. [•]



Una vez el usuario está conectado al nodo del atacante, el cibercriminal tiene acceso a todos los movimientos del usuario, e incluso a los datos que este introduzca durante su navegación (perfiles de usuario completos junto a contraseñas).

Siempre que estemos en una red pública, tenemos que asegurarnos de estar en el nodo correcto, el que la empresa o local en el que estemos haya capacitado para que nos conectemos. Si duda de cuál es el punto de conexión, antes de conectarse, pregunte a algún empleado o responsable del lugar.

06- Configuraciones básicas del router o puerta de enlace

Tras contratar un servicio a nuestro ISP, lo cotidiano es recibir la visita de un instalador que realizara la configuración de base de nuestra red domestica.

¿Es recomendable modificar la configuración del router?

Sí. Por defecto los ISP emplean claves y tags de red “genéricos”, por esto mismo es conveniente modificar los perfiles de seguridad de nuestra red. [•]

Si no se siente capaz de realizar esta configuración no la haga. Busque ayuda profesional, o algún amigo o conocido que esté familiarizado con este procedimiento.

Parámetros que es recomendable modificar:

[Básicos]

[SSID] o “Nombre de la red”

Es muy recomendable cambiar este nombre, e incluso “ocultarlo” para que ningún vecino ni atacante pueda verlo al escanear las redes.

¿Si el nombre está oculto como me conecto?

Escribiendo el nombre en su respectivo campo junto al password. Ocultar el “SSID” no hace que la red “desaparezca” simplemente no se puede ver “listada”.

Modificar la clave de acceso a red

Es recomendable eliminar la clave genérica, e introducir una personalizada.

Seguridad de la clave

Asegurarnos de estar empleando un sistema de cifrado **WPA2** o **WPA3**



07- Protección de privacidad en dispositivos móviles

Los dispositivos móviles cuentan con infinidad de sensores y capacidades técnicas, que por defecto, todas las aplicaciones o APPS pueden “leer”. Esto que a la par puede parecer inofensivo, es algo que el usuario tiene que gestionar, aplicación por aplicación. [4]

¿Debo darle acceso a esta app a mis contactos?

¿O a mis SMS? ¿Y al micrófono?

Este interrogante se nos presenta una y otra vez cada vez que instalamos alguna aplicación, pero ¿sabemos realmente las consecuencias que puede tener para nosotros un uso fraudulento de los permisos que concedemos?

Principales permisos y riesgos para nuestra privacidad y seguridad

Con cada permiso que damos, **proporcionamos información sobre nosotros**. Si la app tiene malas intenciones, sufre algún error, o un ciberataque, puede ponernos en riesgo.

Riesgos	Calendario Conocer y cambiar nuestras citas, fechas, reuniones y rutinas.	Contactos Acceder a nuestra lista de contactos y ver la lista de cuentas de servicios.	Cámara Micrófono Realizar grabaciones de video, audio o tomar fotografías.	Memoria Acceder o modificar cualquier archivo o dato almacenado.	Mensajes De texto Acceder, modificar, o enviar mensajes SMS.	Sensores Del cuerpo Conocer datos sensibles sobre nuestra salud y actividad física.	Teléfono Acceder al histórico de llamadas y funcionalidades del teléfono.	Ubicación Conocer nuestra ubicación en tiempo real.	Otros permisos Que debemos revisar por no estar exentos de riesgos.
Suplantación de identidad	✓	✓	✓	✓	✓				
Robo de datos personales y confidenciales	✓			✓	✓		✓		
Publicidad dirigida	✓		✓			✓		✓	
Ataques de ingeniería social y phishing	✓	✓		✓	✓	✓	✓	✓	
Riesgo para la seguridad física	✓							✓	
Envío de spam, fraudes y malware		✓			✓		✓		
Pérdida de privacidad			✓					✓	
Extorsión/sextorsión			✓	✓					
Suscripción a servicios premium					✓		✓		
Difusión de datos sobre el estado de salud						✓			
Administradores del dispositivo: control total del dispositivo									✓
Instalar aplicaciones desconocidas: instalación de cualquier app									✓
Acceso a las notificaciones: lectura de mensajes de otras app, sms, llamadas									✓
Accesibilidad: cambiar los controles del dispositivo									✓

No lo olvides, los usuarios somos la primera barrera de seguridad.
Utiliza el sentido común y no des permisos que no sean necesarios para la funcionalidad que ofrece la app.

www.incibe.es | www.osi.es


GOBIERNO DE ESPAÑA


VICEPRESIDENCIA
TERCERA DEL GOBIERNO
MINISTERIO
DE ASUNTOS ECONÓMICOS
Y TRANSFORMACIÓN DIGITAL


SECRETARÍA DE ESTADO
DE DIGITALIZACIÓN
E INTELIGENCIA ARTIFICIAL


INSTITUTO NACIONAL DE CIBERSEGURIDAD


Oficina de Seguridad del Internauta






@INCIBE @osiseguridad

08- Protección de datos, los derechos que tiene el usuario

CUÁLES SON TUS DERECHOS DE PROTECCIÓN DE DATOS

La normativa de protección de datos te otorga una serie de derechos. Para ejercerlos, debes dirigirte ante quien está tratando tus datos ("responsable")

aepd
agencia
española
protección
datos



Derecho de información

El responsable siempre debe identificarse, informarte para qué se utilizan tus datos y además decirte:

- La razón por la que tus datos son necesarios
- Hasta cuándo los conservará
- Cómo puedes ejercer tus derechos de protección de datos
- Cuál es la base jurídica del tratamiento
- Si los va a ceder a terceros o transferir a otros países
- Si los van a utilizar para elaborar perfiles tienes **derecho a oponerte si se adoptan decisiones automatizadas** que te afecten jurídicamente o de manera similar



Derecho de rectificación

Te permite corregir tus datos o completarlos si son inexactos o incompletos.



Derecho de oposición

Puedes oponerte a que una entidad trate tus datos:

- Por motivos personales salvo que el responsable acredite un interés legítimo
- Cuando el tratamiento tenga por objeto el marketing directo



Derecho de supresión ("derecho al olvido")

Puedes solicitar la eliminación de tus datos personales cuando:

- Ya no sean necesarios para los fines para los que se recogieron
- Retires el consentimiento que diste, siempre que no haya otra causa que legitime el tratamiento
- Tus datos hayan sido tratados ilícitamente
- Te hayas opuesto a su tratamiento y no prevalezca el interés legítimo, o si el tratamiento tuviera por objeto el marketing directo
- Deban suprimirse para cumplir una obligación legal
- Se hayan obtenido siendo menor de edad en relación con los servicios de la sociedad de la información



Derecho a la limitación de tratamiento

Permite solicitar la suspensión del tratamiento de tus datos cuando:

- Impugnes su exactitud, durante el periodo en el que se comprueba
- Te opongas al tratamiento, mientras se verifica si prevalece el interés legítimo del responsable
- El tratamiento sea ilícito, pero te opones a su supresión y en su lugar solicitas que se limite
- Cuando los necesites para la formulación, ejercicio o defensa de reclamaciones



Derecho a la portabilidad

Cuando el tratamiento esté basado en tu consentimiento o en la ejecución de un contrato, y se efectúa por medios automatizados, puedes recibir tus datos en un formato que permita transmitirlos a otro responsable.

Más información sobre tus derechos y cómo ejercerlos en:

<https://www.aepd.es/es/derechos-y-deberes/conoce-tus-derechos>

www.aepd.es

[AEPD_es](https://twitter.com/AEPD_es)